

ISO 27001, RGPD, NIS2 : par où commencer ?

Ce guide résume les questions à se poser avant d'engager une démarche de mise en conformité, et les erreurs les plus fréquentes observées sur nos missions.

Les 4 référentiels à connaître

- **ISO 27001** — le standard international du management de la sécurité de l'information — souvent exigé par les grands donneurs d'ordre.
- **RGPD** — encadre la protection des données personnelles, avec des obligations de notification en cas de fuite.
- **NIS2** — étend les exigences de cybersécurité aux opérateurs d'importance, au-delà des seuls grands groupes.
- **DGSSI** — référentiel marocain de sécurité des systèmes d'information pour les infrastructures sensibles.

Les 3 erreurs les plus fréquentes

- **Copier une politique générique** — une politique de sécurité qui ne reflète pas vos processus réels ne survit jamais au premier audit de surveillance.
- **Sous-estimer le délai** — une certification ISO 27001 prend en moyenne 6 à 12 mois — pas 6 semaines.
- **Traiter la conformité comme un projet ponctuel** — sans gouvernance continue, la conformité se dégrade dès l'année suivante.

60+
ORGANISATIONS ACCOMPAGNÉES

8 mois
DÉLAI MOYEN ISO 27001

100%
REUSSITE AUDIT INITIAL